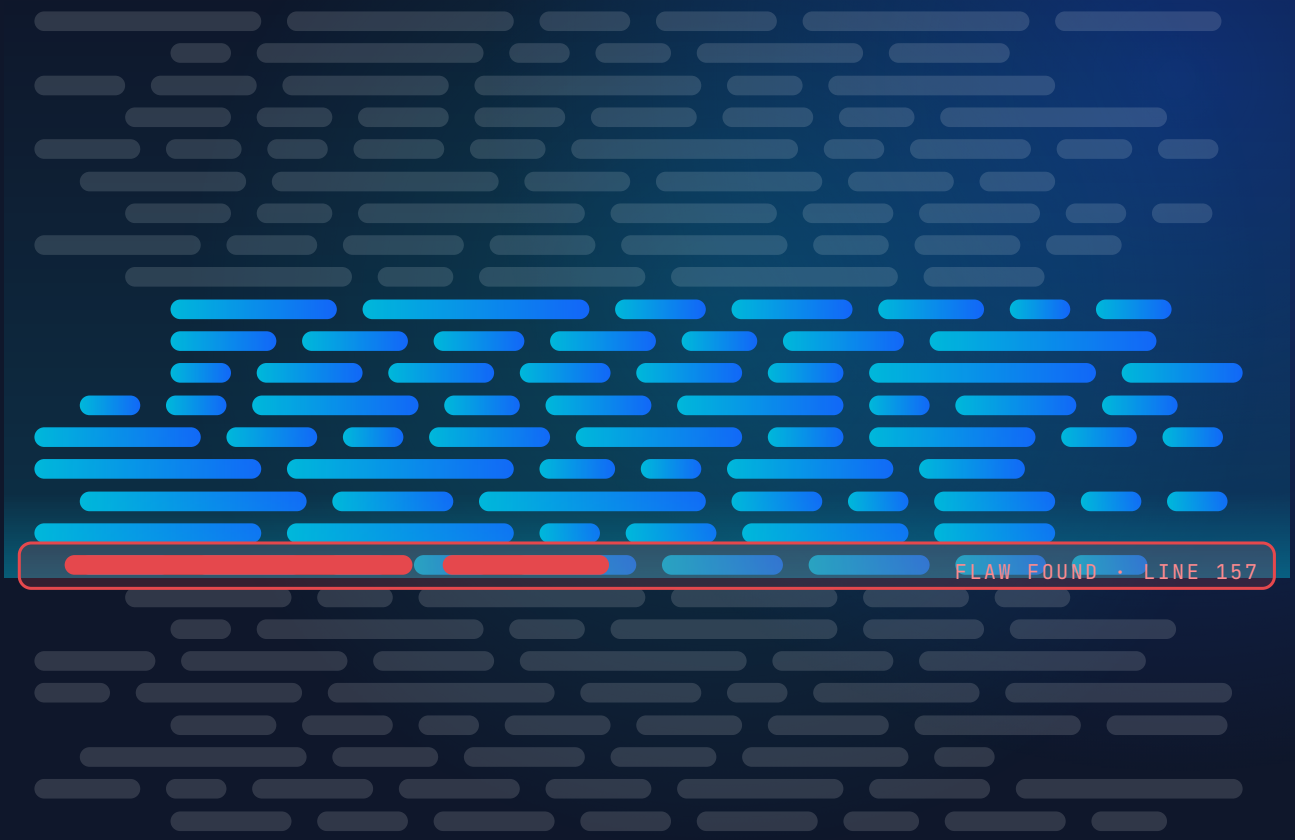
TRANSPUTEC

AI & VULNERABILITIES · OCT 2026



Found by machines.

How AI is changing the hunt for software flaws, and why the gap between a bug and an attack keeps shrinking.

TRANSPUTEC RESEARCH

SAMPLE EDITION

ABOUT THIS REPORT

Who says so, and who sells what.

Most claims about AI and vulnerabilities come from companies that sell security products or AI. We read each source at the page, flag who published it, and say what we could not read.

SOURCE 01

Wiz Research and Calif

Both teams' own PHP2Shell write-ups, October 2026. Both sell security services.

SOURCE 02

DARPA

Results of the AI Cyber Challenge, August 2025. Government, but a competition, not production.

SOURCE 03

Google, XBOW

Big Sleep (2024, 2025) and XBOW's bug-bounty results (2025). Vendor claims.

SOURCE 04

Mandiant M-Trends 2026

Incident-response telemetry from more than 500,000 investigation hours. Vendor-authored.

SOURCE 05

UK NCSC

Impact of AI on cyber threat from now to 2027. Published May 2025; we found no update.

SOURCE 06

News

BleepingComputer, The Register, The Next Web, for what attackers and maintainers did.

READ WITH CARE

Competition and vendor results show what is possible under stated conditions, not what attackers do every day. Nothing here shows that PHP2Shell was exploited by AI-built attacks.

© 2026 Transputec Ltd. Third-party material is quoted with attribution.

CONTENTS

Inside.

Executive summary 04

01 **What AI actually changed** 05

Humans and models on PHP2Shell 06

Four years of precedents 07

02 **Scores, and the small print** 08

The flood of noise 09

03 **What defenders face** 10

The UK government view 11

04 **What to do** 12

Sources and method 13

EXECUTIVE SUMMARY

The machines are good at proving a bug can be used.

54 of 63

of 63 planted flaws found by the best AI systems in DARPA's 2025 final, with 43 patched[6]

45 min

minutes: the average time those systems took to patch a flaw[6]

−7 days

days: Mandiant's estimated mean time to exploit, so attacks often precede a patch[9]

4 days

days between the first recorded PHP2Shell attempt and the fix[3]

What happened

The PHP2Shell flaws were found by researchers using frontier AI models. Wiz says the code had sat there for more than a decade and that what AI changed was turning the weaknesses into working exploits, in hours. Calif, the other team, warns that no model finds all bugs from simple prompts, and that knowing your target still matters.[1,2]

What it means

Treat the next critical flaw in old, widely used software as more likely to be found, and to be usable sooner. The NCSC judges that the time between disclosure and exploitation has shrunk to days and that AI will almost certainly shrink it further.[10]

Our view: the useful response is not a new tool. It is a patch process measured in hours for anything facing the internet.

KEEP CALIBRATED

Mandiant says 2025 was not the year breaches were the direct result of AI; most intrusions still come from basic failures.[9]

Sources: 1 Wiz. 2 Calif. 3 BleepingComputer. 6 DARPA. 9 Mandiant M-Trends 2026. 10 NCSC.

CHAPTER 01 · WHAT AI ACTUALLY CHANGED

A week

is how long Wiz says a single researcher needed for work that would once have taken a world-class team months. It is Wiz's own claim, and it is unquantified.[1]

The bug was old. The exploit was new.

01

01 · WHAT AI ACTUALLY CHANGED

Humans steered. Models did the heavy lifting.

Both teams describe human-led work with AI assistance. Neither describes an autonomous discovery.

RESEARCHERS

- Chose a target they knew well, with a deep history of vulnerabilities
- Decided where to look and which results mattered
- Judged what was exploitable and what was noise
- Coordinated disclosure with the PHP maintainers

AI MODELS

- Helped understand weaknesses in old code
- Helped turn them into working exploits
- Adapted exploits across several applications in hours
- Scaled the audit: Wiz used three AI tools, Calif general models anyone could use

CALIF, IN ITS OWN WORDS

"No model is simply capable of unearthing 'all bugs' with simple prompts. At least for now."[2]

Calif adds that it expected to find nothing critical, because every lab had already run AI-assisted audits of PHP. It surfaced the first issue within days.[2]

HISTORY

A related out-of-memory problem was reported in 2020 and rediscovered in a 2024 audit, but exploitation was not proven, so it was not fixed.[2] That is the pattern AI changes: a flaw that is known but unproven stops being safe.

Sources: 1 Wiz Research, 21 Oct 2026. 2 Calif PHP2Shell write-up. Both are security vendors.

01 · WHAT AI ACTUALLY CHANGED

Four years of precedents.

NOV 2024

Big Sleep's first find

Google's Big Sleep agent finds an exploitable memory flaw in SQLite, fixed the same day, before it reached an official release. Google believes it is the first public example of its kind.[5]

JUN 2025

A bot tops a bug bounty board

XBOW submits nearly 1,060 vulnerabilities to HackerOne, reviewed by its team before sending, and reaches the top of the US leaderboard.[7]

JUL 2025

Foiling an attack

Google says Big Sleep, with threat intelligence, found a SQLite flaw (CVE-2025-6965) that was about to be exploited, and cut it off. A self-reported first.[5]

AUG 2025

DARPA's final

AI systems find 54 of 63 planted flaws and patch 43, and also find 18 real, previously unknown ones.[6]

JAN 2026

curl closes its bounty

Daniel Stenberg ends curl's bug bounty to remove the incentive for low-quality, AI-generated reports.[8]

OCT 2026

PHP2Shell

Researchers use frontier models to find and weaponise flaws in PHP, then disclose them. Attacks begin four days before the patch.[1,2,3]

Sources: 5 Google Project Zero and Google. 6 DARPA. 7 XBOW. 8 The Register. 1-3 as listed. Several of these are vendor claims.

02

02 · SCORES, AND THE SMALL PRINT

Impressive, and not the whole story.

DARPA AI CYBER CHALLENGE FINAL

54 of 63

planted flaws found (86%, against 37% at the semifinals), 43 patched, in an average of 45 minutes, at about $152 per task. They also found 18 real, unknown flaws and patched 11.[6]

READ THE CONDITIONS

These are competition results on defined targets, run under stated rules. They show what is achievable, not what attackers do daily.[6]

XBOW ON HACKERONE · WHAT HAPPENED TO THE REPORTS



RESOLVED 130

TRIAGED 303

DUPLICATES 208

INFORMATIVE 209

Of nearly 1,060 submissions, 130 were resolved and 303 triaged. 208 were duplicates and 209 informative. That is a strong hit rate and a lot of reports for humans to sort.[7]

Sources: 6 DARPA, 8 August 2025. 7 XBOW (a vendor), 24 June 2025. The four groups shown do not account for every submission.

02 · SCORES, AND THE SMALL PRINT

The same tools make noise at scale.

7

reports received by curl in a single week in January 2026. None was a real vulnerability.[8]

"Remove the incentive for people to submit crap and non-well researched reports to us. AI generated or not."

Daniel Stenberg, curl maintainer, as quoted by The Register. He also accepted that AI can be a fine bug-hunting aid after receiving good AI-assisted reports.[8]

WHY IT MATTERS TO YOU

Open-source maintainers are the unpaid backstop for software your business runs. If good reports drown in bad ones, fixes slow down for everyone downstream. Ask your suppliers how they track and fund the open-source components they depend on.

03

03 · WHAT DEFENDERS FACE

Faster, but not yet AI-made.

Mandiant's incident-response data shows exploitation getting quicker and hand-offs between attackers collapsing. It does not blame AI.

−7 days

estimated mean time to exploit in 2025, meaning exploitation routinely happens before a patch exists.[9]

22 sec

median hand-off from initial access to a second threat group in 2025, against more than eight hours in 2022.[9]

32%

of intrusions began with an exploit, the top vector for the sixth year.[9]

11%

began with voice phishing.[9]

14 days

global median dwell time, up from 11.[9]

MANDIANT

"We do not consider 2025 to be the year where breaches were the direct result of AI… the vast majority of successful intrusions still stem from fundamental human and systemic failures."[9]

Source: 9 Google Cloud / Mandiant, M-Trends 2026 (23 March 2026), based on more than 500,000 hours of investigations. Vendor telemetry.

03

03 · WHAT DEFENDERS FACE

What the NCSC said.

The UK's National Cyber Security Centre assessed the impact of AI on the cyber threat out to 2027.

Frequency and intensity	"AI will almost certainly continue to make elements of cyber intrusion more effective and efficient, leading to an increase in frequency and intensity of cyber threats."[10]
Vulnerability research	"The most significant AI cyber development will highly likely come from AI-assisted vulnerability research and exploit development. The time between disclosure and exploitation has shrunk to days and AI will almost certainly reduce this further."[10]
A widening divide	"There will almost certainly be a digital divide between systems keeping pace with AI-enabled threats and a large proportion that are more vulnerable."[10]
A limit	"Fully automated, end-to-end advanced cyber attacks are unlikely to 2027."[10]

DATE

The assessment was published on 7 May 2025. We found no 2026 update to it. Its judgements pre-date PHP2Shell and are consistent with it.

Source: 10 NCSC, Impact of AI on cyber threat from now to 2027 (7 May 2025). Government assessment.

04 · WHAT TO DO

Five habits for a shorter window.

None needs an AI tool. All of them are about speed and knowing what you run.

Shrink the window	Patch and restart anything internet-facing in hours, not weeks. Assume attacks may start before the fix.	PLAY 02
Know your estate	List every place a widely used component runs, including inside appliances and containers.	PLAY 01
Retire the old	Move end-of-life software onto supported versions. There may be no fix when it matters.	PLAY 05
Look back	When a flaw is announced, review logs from before the disclosure date.	PLAY 03
Back the maintainers	Ask suppliers how they fund and track the open-source parts they ship.	PLAY 05

SOURCES AND METHOD

Where this comes from.

1 Wiz Research. **PHP2Shell.** 21 October 2026. wiz.io/blog/php2shell-php-rce. Vendor.

2 Calif. **PHP2Shell write-up.** calif.io/php2shell/. Security consultancy; undated page with entries to 21 October 2026.

3 BleepingComputer. **Amazon says PHP2Shell exploitation began 4 days before patches.** 22 October 2026 (quotes Amazon Threat Intelligence and Dataminr).

4 The Register, 23 October 2026 (PHP Foundation statement on no evidence of successful exploitation prior to disclosure).

5 Google Project Zero. **From Naptime to Big Sleep.** 1 November 2024; Google, 15 July 2025 (blog.google). Vendor.

6 DARPA. **AIxCC results.** 8 August 2025. darpa.mil/news/2025/aixcc-results.

7 XBOW. **Top 1: how XBOW did it.** 24 June 2025. xbow.com. Vendor.

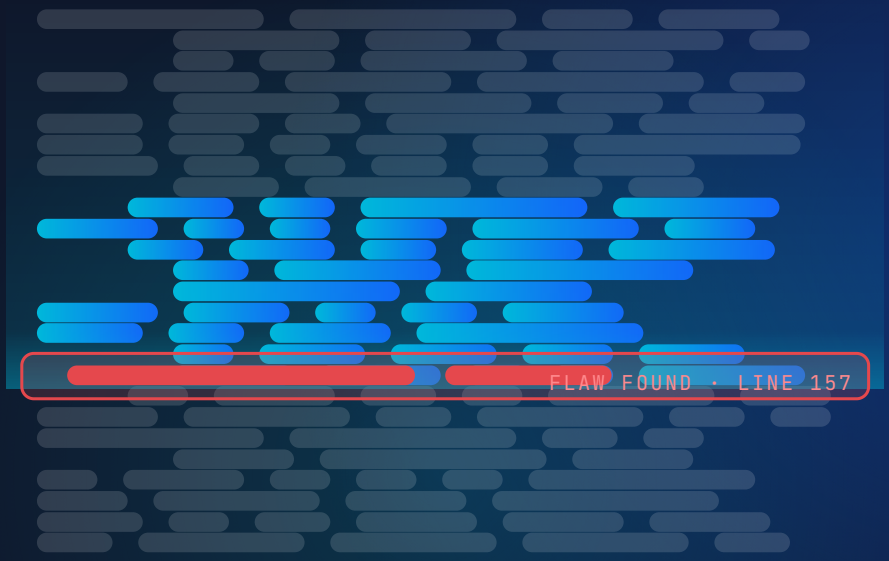
8 The Register. **curl ends bug bounty.** 21 January 2026.

9 Google Cloud / Mandiant. **M-Trends 2026.** 23 March 2026. cloud.google.com/blog/topics/threat-intelligence/m-trends-2026. Blog post read; full report not read.

10 NCSC. **Impact of AI on cyber threat from now to 2027.** 7 May 2025. ncsc.gov.uk/report/impact-ai-cyber-threat-now-2027.

METHOD NOTES

Accurate as of 27 October 2026. We could not read OpenAI's own pages (blocked), so we make no claims that rest on them. A White House statement on AI incident disclosure was reported only second-hand and is not used. Calif refers to OpenAI's programme as Patch the Planet; some press calls it Hack the Planet. M-Trends' time-to-exploit estimate is not attributed to AI by its authors. Vendor and competition results are labelled as such.



MACHINES FIND THEM. PEOPLE FIX THEM.

TRANSPUTEC

Managed IT, cyber and AI for UK businesses.
Patching and incident response under SLA.

LRQA CERTIFIED · LRQA CERTIFIED ISO 14001 · CYBER ESSENTIALS CERTIFIED PLUS · OFFENSIVE SECURITY OSCP

Microsoft Solutions Partner — Modern Work

Microsoft Solutions Partner — Security

aws PARTNER Advanced Tier Services

CISCO Partner